هجوم برمجية الفدية WannaCry (2017)

ليش تضررت جهات كثيرة مع إن التحديث الأمني كان موجود قبله؟

الاسم: تميم تركي الحارثي

الكلاس: 103

البحث: بحث الأمن السيبراني – الموضوع 1

التاريخ: 1 نوفمبر 2026

الملخص

في 12 مايو 2017 انتشرت برمجية فدية اسمها WannaCry بسرعة كبيرة حول العالم، وأصابت أكثر من 200 ألف جهاز في حوالي 150 دولة خلال أيام. البرمجية كانت تشفر ملفات الجهاز وتطلب فدية بعملة البيتكوين (300 دولار تزيد مع الوقت)، وتنتقل لحالها من جهاز لجهاز داخل الشبكة. من أكثر الجهات اللي تضررت هيئة الصحة البريطانية (NHS)، اللي انلغت فيها آلاف المواعيد والعمليات. والغريب إن مايكروسوفت كانت نازلة تحديث يسد الثغرة اللي استغلها الهجوم قبل حوالي شهرين (في 14 مارس 2017)، بس جهات كثيرة ما ثبتته أو كانت تستخدم أنظمة قديمة. يعني المشكلة الأساسية ما كانت إن ما فيه حل، بل إن دورة معالجة الثغرات ما اشتغلت صح.

التحليل

1) ما الأصول اللي تضررت؟ وأي ركن تأثر؟

الأصل	الركن	التوضيح
ملفات وبيانات الجهات (سجلات مرضى، ملفات شغل)	**التوفر** (الأهم)	الملفات ما انسرقت بالضرورة، بس انقفلت بالتشفير وصار أصحابها ما يقدرون يوصلونها.
الأجهزة والشبكات (أجهزة مستشفيات، شاشات، أنظمة شركات)	**التوفر** + **السلامة**	الأجهزة وقفت عن الشغل، والبرمجية غيرت الملفات (شفرتها)، فالبيانات ما عادت على حالها الصحيحة.
الخدمات (المواعيد الطبية، الطوارئ)	**التوفر**	بعض المستشفيات حولت مرضى الطوارئ لمستشفيات ثانية وانلغت مواعيد كثيرة.

2) مين جهة التهديد؟

حكومتا أمريكا وبريطانيا نسبتا الهجوم رسميا في ديسمبر 2017 لمجموعة مرتبطة بكوريا الشمالية تعرف باسم «لازاروس». وتصنيفها:

الدافع	مالي بالدرجة الأولى (طلب فدية)، مع احتمال دافع تخريبي، لأن المبالغ اللي انجمعت كانت قليلة مقارنة بحجم الهجوم.
القدرة	عالية: استخدموا أداة اختراق متقدمة اسمها EternalBlue كانت تسربت للإنترنت في أبريل 2017، وبنوا برمجية تنتشر لحالها.
الوصول	عن بعد عبر الإنترنت، من خلال خدمة مشاركة الملفات بويندوز (SMBv1) لما تكون مكشوفة، وبعدها تنتقل داخل الشبكة لباقي الأجهزة.
الهدف	ما كان هدف محدد: أي جهاز ويندوز ما فيه التحديث. عشان كذا تضررت مستشفيات وشركات ومصانع بالصدفة.

3) وش نوع الضعف اللي استغلوه؟

- **خلل تنفيذ:** الثغرة نفسها كانت خطأ في برمجة خدمة SMBv1 بويندوز، يخلي المهاجم يشغل أوامر على الجهاز عن بعد.
- **ضابط مفقود:** الجهات المتضررة ما كان عندها إدارة تحديثات فعالة، فالتحديث موجود وما انثبت. وكثير منها ما عنده نسخ احتياطية جاهزة.

- **إعداد غير آمن:** خدمة SMBv1 قديمة وكانت شغالة ومفتوحة على الإنترنت في بعض الأجهزة بدون حاجة، والشبكات ما كانت مقسمة فانتشر الهجوم داخلها بسهولة.

4) تسلسل زمني مختصر

التاريخ	الحدث
14 مارس 2017	مايكروسوفت تنزل النشرة الأمنية MS17-010 وتحديث يسد ثغرة SMBv1 بالأنظمة المدعومة.
14 أبريل 2017	مجموعة اسمها Shadow Brokers تنشر أدوات اختراق مسربة، منها EternalBlue اللي تستغل نفس الثغرة.
12 مايو 2017	يبدأ هجوم WannaCry وينتشر بسرعة في أوروبا وآسيا، ويضرب مستشفيات NHS.
12 مايو 2017 (مساء)	باحث أمني يلاحظ إن البرمجية تتصل بنطاق غير مسجل، يسجله، فيتوقف الانتشار بشكل كبير (مفتاح الإيقاف Kill switch).
13 مايو 2017	مايكروسوفت تنزل تحديث طارئ حتى للأنظمة القديمة اللي وقف دعمها مثل Windows XP.
ديسمبر 2017	أمريكا وبريطانيا تنسبان الهجوم رسميا لكوريا الشمالية.

5) أين فشلت دورة معالجة الثغرات؟

المرحلة	نجحت؟	التوضيح
الاكتشاف	نجحت	الثغرة انعرفت ومايكروسوفت نشرت نشرة أمنية واضحة قبل الهجوم بشهرين.
التحقق	فشلت جزئيا	جهات كثيرة ما كانت تعرف وش الأجهزة اللي عندها ولا وش الأنظمة القديمة الشغالة فيها، فما تحققت هل هي متأثرة.
تحديد الأولوية	فشلت	النشرة كانت بتصنيف «حرج»، بس كثير من الجهات ما عطتها أولوية، وبعضها أجل التحديث خوفا من تعطل الأجهزة الطبية.
الإصلاح	فشلت	التحديث ما انثبت، وبعض الأجهزة كانت على أنظمة منتهية الدعم ما لها تحديث وقتها.
التأكد	فشلت	ما كان فيه متابعة تتأكد إن كل الأجهزة فعلا تحدثت، فبقيت أجهزة كثيرة مكشوفة.

يعني الفشل ما كان بالاكتشاف، بل بالخطوات اللي بعده داخل الجهات نفسها.

6) لو صار شي مشابه بمدرستي، كيف أقيم خطره؟

لو أجهزة معمل المدرسة أو أجهزة الإدارة ما تتحدث بانتظام وكلها على نفس الشبكة: **الاحتمالية = 3 من 5** (برمجيات الفدية منتشرة، بس المدرسة مو هدف محدد وفيها برنامج حماية)، و**الأثر = 4 من 5** (توقف الدراسة بالمعمل، وضياع درجات وملفات الطلاب لو ما فيه نسخ احتياطية). فالدرجة = 3 × 4 = **12 (متوسط–عالي)**، والمعالجة المناسبة **تقليل** الخطر بتشغيل التحديثات التلقائية والنسخ الاحتياطية.

الضوابط المقترحة

	وقائي	كاشف	تصحيحي
أشخاص	توعية الموظفين والطلاب بأهمية التحديثات وعدم تأجيلها، وعدم تشغيل ملفات غير معروفة.	تشجيع الكل يبلغ فورا لو ظهرت رسالة فدية أو صارت الملفات غريبة.	فريق معروف يتواصلون معه، يفصل الجهاز المصاب عن الشبكة بسرعة.
إجراءات	سياسة إدارة التحديثات: التحديثات الحرجة تنثبت خلال أيام، وقائمة بكل الأجهزة وأنظمتها.	مراجعة شهرية: أي جهاز ناقصه تحديثات أو نظامه منتهي الدعم.	خطة استجابة: نرجع البيانات من النسخ الاحتياطية بدل دفع الفدية، ونبلغ الجهات المختصة.
تقنية	تثبيت التحديثات، إيقاف SMBv1، جدار حماية يمنع المنافذ المكشوفة، وتقسيم الشبكة.	برنامج حماية يكشف البرمجيات الضارة ويرسل تنبيه، ومراقبة الشبكة لأي انتشار غريب.	نسخ احتياطية منتظمة ومفصولة عن الشبكة، واستعادة الأجهزة من نسخة نظيفة.

الدروس المستفادة

1. **لا تأجل التحديثات:** في المدرسة والبيت، التحديث اللي يطلب إعادة تشغيل مو إزعاج، هو اللي كان بيحمي آلاف الأجهزة من WannaCry. وجود الحل ما ينفع إذا ما انثبت.
2. **النسخة الاحتياطية تنقذك:** لو عندك نسخة من ملفاتك المهمة (مشاريعك، صورك) على قرص منفصل أو خدمة سحابية، برمجية الفدية ما تقدر تبتزك.
3. **الأجهزة القديمة خطر على الكل:** جهاز واحد قديم ما يتحدث على شبكة المدرسة ممكن ينقل الإصابة لكل الأجهزة، فلازم تتحدث أو تنفصل عن الشبكة.

رسالة توعية

تحديث اليوم يحمي ملفاتك بكرة

في 2017 توقفت آلاف الأجهزة حول العالم بسبب برمجية فدية، مع إن الحل كان موجود: تحديث بسيط ما انثبت. عشان كذا، لا تأجل تحديثات جهازك وجوالك، وخل التحديث التلقائي شغال. واحفظ نسخة من ملفاتك المهمة في مكان ثاني. ولو ظهرت لك رسالة غريبة تطلب فلوس عشان ترجع ملفاتك، لا تدفع ولا تضغط على شي، افصل الجهاز عن الإنترنت وبلغ قسم التقنية بالمدرسة على طول.

عدد كلمات الرسالة: حوالي 65 كلمة.

المصادر

1. UK National Audit Office (NAO) – Investigation: WannaCry cyber attack and the NHS (2017):
   https://www.nao.org.uk/reports/investigation-wannacry-cyber-attack-and-the-nhs/
2. Microsoft – Security Bulletin MS17-010 (Critical), March 14, 2017:
   https://learn.microsoft.com/en-us/security-updates/securitybulletins/2017/ms17-010

3. CISA (US Cybersecurity and Infrastructure Security Agency) – Indicators Associated With WannaCry Ransomware:
https://www.cisa.gov/news-events/alerts/2017/05/12/indicators-associated-wannacry-ransomware
4. Microsoft Security Response Center – Customer Guidance for WannaCrypt attacks (May 12, 2017):
https://msrc.microsoft.com/blog/2017/05/customer-guidance-for-wannacrypt-attacks/

استخدام أدوات الذكاء الاصطناعي: _____ (اكتب هنا وش استخدمتها فيه، مثلا: فهم التسلسل الزمني للهجوم وترتيب جدول الضوابط).